

The logo consists of the word "instamart" in a white, lowercase, sans-serif font, centered within a solid orange rounded rectangle.

PRODUCT REQUIREMENTS DOCUMENT

DPDP-Compliant Consent Redesign

The Instamart Privacy Hub

Owner: Product Management — Privacy & Trust, Instamart

Status: Draft for Review · Version 1.0 · July 2026

Distribution: Engineering · Design · Legal & Compliance · Data Science · Leadership

REFERENCE ARTIFACTS

[Clickable MVP prototype → https://instamart-privacy-hub.vercel.app/](https://instamart-privacy-hub.vercel.app/)

[GitHub repository → https://github.com/VatsuAgarwal/Swiggy-Instamart-DPDP-Complaint-Experience-MVP](https://github.com/VatsuAgarwal/Swiggy-Instamart-DPDP-Complaint-Experience-MVP)

Source strategy deck: Instamart_DPDP_Consent_Deck.pptx

1. Executive Summary

Problem Statement

Instamart currently captures user consent through a single, bundled acceptance of the Terms & Conditions at signup. That one action is treated as blanket permission for order fulfilment, personalisation, marketing communication, and sharing of user data across the wider Swiggy ecosystem and with partners. Users have no purpose-level choice, no visible record of what they agreed to, and no self-serve way to change their mind.

Why This Matters

- India's Digital Personal Data Protection (DPDP) Act, 2023 requires consent to be free, specific, informed, unconditional and unambiguous, given through a clear affirmative action, per purpose — a single bundled checkbox does not meet this bar.
- Users increasingly equate data control with brand trust; competitors who visibly respect user privacy gain a differentiation edge in an otherwise commoditised quick-commerce market.
- Every day of non-compliance is a day of regulatory exposure that compounds as Instamart's user base and data footprint grow.

Business Opportunity

Treated only as a legal obligation, this initiative is a cost centre. Treated as a product surface, it is an opportunity to turn a mandatory disclosure into a trust-building moment — reducing support load from confused users, improving long-term retention among privacy-conscious segments, and creating a reusable Consent-as-a-Service layer the rest of the Swiggy ecosystem (Food, Genie, Dineout) can adopt.

Regulatory Implications

The DPDP Act introduces obligations that Instamart's current flow does not satisfy, including purpose limitation, itemised and withdrawable consent, mandatory plain-language notice, data principal rights (access, correction, erasure, grievance redressal), and heightened protection for children's data requiring verifiable parental consent. Non-compliance carries financial penalties that scale with the severity and duration of the breach, in addition to reputational and regulatory-relationship risk. Exact statutory figures, timelines and thresholds should be confirmed with Legal before external commitments are finalised — see Section 18, Open Questions.

User Trust Considerations

Our target user does not read Terms & Conditions and does not want to. The redesign has to earn trust through clarity and control that costs the user almost no time, not through more text. Every design decision in this PRD is weighed against a simple bar: does it make the user more confident that Instamart respects their data, without adding meaningful friction to the 10-minute order they came to place?

2. Background

Existing Consent Experience

At signup, the user is shown a single Terms & Conditions acceptance step. Accepting it is a prerequisite to using the app at all — there is no path to use core ordering functionality with a narrower set of permissions. Once accepted, the app does not surface this decision again unless the user actively hunts for it inside nested settings menus.

Current User Journey

- Open app for the first time
- Accept Terms & Conditions (bundled consent, one tap)
- Browse and place orders
- Data collected during use silently powers personalisation, marketing targeting, and cross-platform sharing
- No visibility into what was agreed to, and no easy way to view or modify it

Current Gaps vs. DPDP Expectations

DPDP Expectation	Current State	Gap
Purpose-specific, itemised consent	Single bundled acceptance	No mechanism to consent to one purpose without all others
Clear, affirmative action per purpose	Implicit acceptance via T&C	No explicit opt-in captured for optional processing
Easy, no-detriment withdrawal	None — leaving requires deleting the account	Withdrawal is destructive rather than granular
Plain-language notice of processing purpose	Buried in legal T&C text	Users cannot reasonably be expected to understand what they agreed to
Data principal rights (access / correction / erasure)	Not self-serve; would route through generic support	No dedicated, timely fulfilment path
Verifiable parental consent for children's data	Not implemented	No age-detection or guardian-verification mechanism exists

Risks of Continuing with Bundled Consent

- Legal: consent captured today would likely not withstand regulatory scrutiny as valid, specific consent.
- Operational: any future data principal request (access, correction, deletion) has no defined fulfilment pipeline, creating ad-hoc support burden and SLA risk.
- Reputational: a public complaint or Data Protection Board inquiry surfaces poorly if Instamart cannot show granular, timestamped consent records.
- Strategic: retrofitting consent under regulatory or media pressure is materially more expensive and reputationally costlier than building it proactively.

3. User Persona

Primary Persona — Rahul, 26, Bengaluru

Attribute	Detail
Role	Product Analyst, orders groceries via Instamart 4–5 times a week
Goals	Fast, frictionless checkout; recommendations that actually save him time; a sense that he — not the app — is in control of his data
Behaviours	Rarely opens Settings; makes checkout decisions in seconds; skims rather than reads; expects consumer apps to behave like the best ones he uses (UPI apps, Gmail)
Pain points today	Privacy settings are effectively undiscoverable; unclear which marketing channels he's opted into; no idea what is shared between Instamart, Swiggy, and Genie
Privacy expectations	Wants transparency without needing to read a legal document; wants toggle-level control that's reachable in two taps; will tolerate one extra screen at onboarding, not five

Secondary Persona — Priya, 34, Parent / Family Account Holder

Priya occasionally lets her 15-year-old use her Instamart account, and is considering creating a separate profile for him. She is the reference persona for the parental consent journey in Section 9 and the children's-data edge cases in Section 17. This persona is a reasonable assumption for design purposes, not sourced from user research, and should be validated once the parental consent flow moves into scoped design work.

4. Problem Definition

User Problem	Compliance Problem	Business Impact	Evidence / Assumptions
Users don't know what data is collected or why	No purpose-specific, explicit consent captured (DPDP consent & notice provisions)	Regulatory penalty exposure; erodes trust silently until a complaint surfaces it publicly	Assumption, based on the current bundled T&C pattern observed in the live app
Opting out of marketing requires deleting the whole account	No granular, no-detriment withdrawal mechanism	Inflated churn; users leave the platform entirely to escape unwanted marketing	Assumption, based on absence of a visible in-app opt-out control
No visibility into cross-platform data sharing (Swiggy Food, Genie, Dineout)	No transparency of processing purposes or data-sharing notice	Risk of Data Protection Board complaints and adverse press if surfaced externally	Assumption, based on Swiggy's shared account and backend infrastructure across its apps
No self-serve way to access, correct, or delete personal data	Data principal rights (access, correction, erasure) not supported	Manual, unscalable support burden; SLA risk once request volume grows	Assumption, based on absence of any visible feature in the current app
No safeguard for accounts used by or for minors	Children's data protections not implemented (verifiable parental consent)	Elevated regulatory risk given DPDP's stricter treatment of children's data	Assumption: some accounts are used by or on behalf of minors, e.g. ordering snacks on a parent's phone

5. Goals

Business Goals

- Reach ≥85% Valid Consent Coverage across monthly active users within 60 days of full rollout.
- Reduce compliance-related legal and support cost by replacing ad-hoc handling with a defined, auditable process.
- Strengthen brand trust relative to competitors, using consent transparency as a differentiator rather than a liability.

User Goals

- Get through the consent step in under 15 seconds without feeling like a legal transaction.
- Understand, in plain language, what each category of data is used for.
- Reach and modify privacy preferences in two taps or fewer, at any time, without contacting support.

Compliance Goals

- Enforce purpose limitation — each category of processing maps to an explicit, itemised consent purpose.
- Capture explicit, specific, and informed consent with a timestamp and version reference for every purpose.
- Support easy, immediate withdrawal with no requirement to delete the account or lose access to core service.
- Provide accessible, timely fulfilment of data principal rights (access, correction, erasure).
- Implement verifiable parental consent before processing a minor's personal data beyond what's essential.

6. Success Metrics

North Star Metric

Field	Detail
Name	Valid Consent Coverage (VCC)
Definition	Share of monthly active users who hold a current, purpose-specific, DPDP-valid consent record
Formula	$(\text{Users with a valid consent record across all active purposes} \div \text{Monthly Active Users}) \times 100$
Target	≥ 85% within 60 days of Phase 3 (enforced purpose-based consent) going live
Measurement frequency	Daily, with a rolling 7-day trend view on the Privacy Health dashboard
Owner	Product Manager, Privacy & Trust

Supporting Metrics

Metric	Formula	Target	Frequency	Owner
Consent completion rate at onboarding	$(\text{Users completing the consent step} \div \text{Users who start it}) \times 100$	$\geq 90\%$	Daily	Growth PM
Self-serve consent modification rate	$(\text{Users editing consent per month} \div \text{MAU}) \times 100$	Directional — monitor trend, no fixed target at launch	Monthly	Product Manager, Privacy & Trust
Median data-rights fulfilment time	Median hours from request to fulfilment, by request type	Within internal SLA (Section 11) and inside the DPDP-mandated window	Weekly	Trust & Safety Operations

Guardrail Metrics

Metric	Formula	Target	Frequency	Owner
Recommendation click-through rate	$\text{Clicks on recommended items} \div \text{recommendation impressions}$	No more than a 5% relative drop vs. pre-launch baseline	Weekly	Personalisation Team
Order conversion rate	$\text{Completed orders} \div \text{checkout sessions started}$	No more than a 2% relative drop vs. baseline	Daily	Growth PM
Post-launch app uninstall rate	$\text{Uninstalls} \div \text{active installs}$	No anomalous spike (>10% relative increase week-over-week)	Weekly	Product Analytics

7. Product Principles

Principle	What it means in practice
Compliance without friction	Every legally required step is designed as a normal, fast product interaction — not a legal gate bolted onto the funnel.
Transparency over legal jargon	Every consent surface uses plain language a non-lawyer understands in one read, with legal language available on request, not by default.
User control by default	Optional processing requires an affirmative choice; nothing optional is silently assumed on the user's behalf.
Minimal decision fatigue	Purposes are grouped into a small number of meaningful categories rather than dozens of individual data-point toggles.
Reversible consent decisions	Aside from account deletion, every consent choice can be changed again in the same number of taps it took to set it.

8. Proposed Solution

The Privacy Hub replaces the single bundled Terms & Conditions checkbox with four purpose-based consent categories, each independently controllable, explained in plain language, and editable at any time from a

persistent Privacy Dashboard. This structure is deliberately a middle point between an all-or-nothing accept-all pattern (non-compliant) and fully granular, item-by-item toggles (compliant but likely to cause severe decision fatigue at checkout speed).

Category: Essential

Field	Detail
Purpose	Enable order placement, delivery, and payment processing
Data types collected	Delivery address, payment token/reference, order contents and history required to fulfil the order
Legal basis	Necessary for performance of the contract with the user; not a discretionary consent toggle
Default state	Always on — not user-toggleable
User controls	View-only in the Privacy Hub; underlying values (e.g. saved address) are editable from the user's profile, not from the consent toggle itself
Copy guideline	“Required to place your order — your delivery address and secure payment details.”
Allowed downstream usage	Order fulfilment, payment processing, fraud prevention, customer support for active orders
Dependencies	Payments platform, Logistics/fulfilment systems

Category: Personalisation

Field	Detail
Purpose	Power product recommendations and personalised search ranking
Data types collected	Purchase history, search history, in-app browsing behaviour
Legal basis	Explicit, opt-in consent
Default state	Off until the user affirmatively enables it — see the open legal question on “recommended defaults” in Section 18
User controls	Single category toggle in the Privacy Hub; withdrawing stops new personalised processing and reverts recommendations to non-personalised/contextual ranking
Copy guideline	“Lets us recommend products based on what you've searched for and bought before.”
Allowed downstream usage	Recommendation engine, personalised search ranking — not shared externally
Dependencies	Personalisation/recommendation platform, Search ranking team

Category: Marketing

Field	Detail
Purpose	Send promotional and re-engagement communication
Data types collected	Contact details (email, phone), channel preference, campaign engagement history
Legal basis	Explicit, opt-in consent, revocable per channel at any time

Field	Detail
Default state	Off for every channel (Email, SMS, WhatsApp, Push) until individually enabled
User controls	Category-level toggle plus channel-level sub-toggles (Section 9 covers the drill-down journey)
Copy guideline	“Choose how we can reach you with offers and updates — email, SMS, WhatsApp, or app notifications.”
Allowed downstream usage	Marketing automation / CRM platform, limited to the channels the user has enabled
Dependencies	Marketing/CRM team, messaging service providers

Category: Partner Sharing

Field	Detail
Purpose	Provide aggregated category insights and enable co-marketing with FMCG and brand partners
Data types collected	Aggregated, anonymised purchase pattern data — not raw, identifiable personal data
Legal basis	Explicit, opt-in consent
Default state	Off until affirmatively enabled
User controls	Single toggle; withdrawing halts inclusion in future aggregate exports (historical aggregates already delivered to partners cannot be selectively un-shared, since they are anonymised at the point of export)
Copy guideline	“Share anonymised shopping trends with brand partners — never your name, contact details, or exact address.”
Allowed downstream usage	Aggregate analytics dashboards and campaign targeting provided to partners; must pass through the anonymisation pipeline before export
Dependencies	Data Platform (anonymisation pipeline), Partnerships team, Legal (partner data-sharing agreements)

9. User Experience

Entry Points

- First app launch, before the first order is placed
- Profile → Privacy Dashboard, at any time
- A periodic in-app nudge (“Review your privacy settings”) for existing users being migrated in Phase 3
- A deep link from the data-rights confirmation email

Onboarding Flow

1. Welcome screen introduces the Privacy Hub with a one-line explanation and the four category names.
2. User chooses “Customise my preferences” or “Quick setup with recommended defaults.”
3. Consent categories screen: Essential shown as always-on; Personalisation, Marketing, and Partner Sharing shown as independent toggles.

4. If Marketing is enabled, a channel drill-down screen lets the user pick Email / SMS / WhatsApp / Push individually.
5. Confirmation screen acknowledges the choice and signposts the Privacy Dashboard for future changes.
6. User lands in the app home screen, order-ready.

Settings Access

Profile → Privacy Dashboard surfaces: how many optional categories are currently on, when preferences were last updated, and three entry points — Consent Preferences, Your Data & Rights, and Activity Log.

Consent Modification Journey

7. User opens Privacy Dashboard → Consent Preferences.
8. User toggles a category or channel.
9. Change is saved immediately (no separate “save” step required beyond the toggle itself) and reflected with a timestamp update.
10. A brief confirmation toast confirms the change took effect.

Withdrawal Journey

Withdrawal uses the same toggle as granting — turning a category off is immediate and requires no additional friction, justification, or account-level action. Downstream systems are notified per the SLAs defined in Section 12 (Consent Architecture).

Data Deletion Flow

11. User opens Your Data & Rights → Delete my account & data.
12. A confirmation screen explains what will be deleted, what is legally retained (e.g. records required for tax purposes), and that the action can't be undone.
13. User confirms; a confirmation screen acknowledges the request has been received.
14. Backend erasure workflow runs asynchronously; the user receives an email once complete.

Data Access Flow

15. User opens Your Data & Rights → Download your data.
16. Request is submitted; an async export job is queued.
17. User receives a confirmation that the export is in progress.
18. A secure, time-bound download link is emailed once the export is ready.

Parental Consent Flow (Phase 4 — Proposed)

This journey is not present in the current MVP and is scoped for Phase 4. It is included here so Engineering, Design, and Legal can plan dependencies ahead of that phase.

19. The app detects a signal suggesting the account may belong to or be used by a minor (e.g. a user-declared “family/child profile” mode, or an explicit age field where collected).

20. The app prompts: “This looks like it might be a child's profile — let's verify a guardian.”
21. The parent/guardian verifies via a linked, already-verified adult Swiggy/Instamart account, or another verification method Legal and Identity teams approve.
22. The guardian reviews and sets consent on the child's behalf; Personalisation, Marketing, and Partner Sharing default to off and require explicit guardian action to enable.
23. Guardian consent is confirmed and logged with a periodic re-verification reminder (proposed annually, pending Legal confirmation).

10. Functional Requirements

Requirements are grouped by prefix: CONS (consent capture/control), DATA (data-principal rights), AUD (audit), SYS (cross-system propagation).

ID	Description	Priority	Acceptance Criteria
CONS-001	Users can independently toggle each of the three optional consent categories (Personalisation, Marketing, Partner Sharing).	P0	Toggle state persists across sessions and devices A consent event is stored with user ID, purpose ID, new state, and timestamp An audit-log entry is created for the change Withdrawal is reflected in downstream systems within the SLA defined in Section 12
CONS-002	Users can independently toggle Marketing sub-channels (Email, SMS, WhatsApp, Push).	P0	Each channel has its own persisted state Disabling a channel immediately suppresses future sends on that channel Channel-level state is visible in the Activity Log
CONS-003	Essential category is displayed as always-on and is not user-toggable.	P0	UI renders a locked/disabled toggle state with explanatory copy No API path exists to disable the Essential purpose while the account remains active
CONS-004	System captures a timestamped, versioned consent record at first submission (onboarding) and at every subsequent change.	P0	Every consent event stores purpose ID, purpose version, and the specific copy version shown to the user Records are immutable and append-only
CONS-005	Users can access a Privacy Dashboard from their profile showing current consent state and last-updated date.	P0	Dashboard loads current state from the authoritative consent-state store, not a cached client value Last-updated timestamp matches the most recent consent event
CONS-006	“Quick setup with recommended defaults” path is available at onboarding.	P1	Recommended defaults are explicitly displayed to the user before confirmation, not silently applied User must take an affirmative action (tap “Confirm”/“Continue”) to submit — pending Legal sign-off, see Section 18
DATA-001	Users can request an export of their personal data from Your Data & Rights.	P0	Request creates a trackable case with a unique ID Export is delivered via a secure, expiring link within the committed SLA Data included matches the documented data inventory for the account

ID	Description	Priority	Acceptance Criteria
DATA-002	Users can request deletion of their account and personal data.	P0	User sees a clear, specific warning before confirming Data required for statutory retention (e.g. financial records) is excluded from deletion and disclosed as such Deletion completion triggers a confirmation email
DATA-003	Data-rights requests are visible to the user as trackable, status-bearing cases.	P1	Case shows status (Received / In Progress / Completed) Median fulfilment time is measurable per Section 6
AUD-001	Every consent state change generates an immutable audit-log entry.	P0	Log entry includes actor (user or system), timestamp, purpose ID, previous and new state, and consent version Log is exportable for regulator or internal audit review
AUD-002	Users can view their own consent Activity Log.	P1	Log displays human-readable entries ("You turned off Marketing on 3 July 2026") Entries are read-only from the client
SYS-001	Consent state changes propagate to all dependent downstream systems (recommendation engine, marketing platform, partner-data export pipeline).	P0	Withdrawal of Marketing suppresses new sends within a defined SLA (target: real-time to near-real-time) Withdrawal of Personalisation halts new personalised-data usage within a defined SLA (target: same business day) Withdrawal of Partner Sharing excludes the user from the next scheduled aggregate export
SYS-002	Consent state is shared across the Swiggy ecosystem (Instamart, Swiggy Food, Genie, Dineout) wherever the same purpose applies to the same user account.	P1	A single consent service is the source of truth across surfaces Purpose-specific consent given or withdrawn on one surface is honoured on others sharing that purpose
SYS-003	Legacy users (pre-launch) are migrated to an explicit consent state rather than assumed compliant.	P0	Existing users are flagged "legacy/unknown" in the consent-state store Users are re-prompted for explicit consent at next app open before Phase 3 enforcement takes effect
CONS-007	Guest checkout sessions capture Essential-only consent without persisting optional-category state.	P1	No optional consent record is created for unauthenticated sessions User is prompted to create an account to access granular controls
CONS-008	A change to a purpose's definition (materially altering what it covers) triggers re-consent, not a cosmetic copy edit.	P2	Purpose version increments only on material definitional change Users on an outdated purpose version are re-prompted before that purpose continues to apply to them

11. Non-Functional Requirements

Category	Requirement
Performance	Consent read/write round-trip completes within 500ms at the 95th percentile; consent-state checks add no more than 150ms to app-launch latency budget
Security	Consent and personal data records are encrypted at rest and in transit; access is role-based and logged; no plaintext consent identifiers appear in application logs
Auditability	Consent history is stored in an immutable, append-only log, exportable in a regulator- and audit-ready format

Category	Requirement
Accessibility	Consent and Privacy Dashboard screens meet WCAG 2.1 AA, including screen-reader labels for all toggles and a minimum 44×44px tap target
Localization	Consent copy is externalised as translatable strings; launch scope should include English and Hindi at minimum, pending Localization team confirmation of full regional-language coverage
Compliance logging	Every consent state change logs actor, timestamp, purpose ID, purpose version, and (only where strictly necessary and minimised) device/session context
Scalability	Consent service sized to handle Instamart's peak read/write QPS at launch-day and festival-peak traffic; exact sizing to be validated by Engineering against current MAU and growth projections
Availability	Consent service targets 99.9% uptime; checkout must not hard-block on a transient consent-service failure — fail-safe default behaviour is documented and reviewed with Legal
Latency constraints	Consent-state checks on app launch and at checkout are budgeted separately from the core transaction path to avoid compounding latency

12. Consent Architecture

Consent Object Model

A ConsentRecord captures a single point-in-time decision. Key fields: user ID, purpose ID, purpose version, status (granted / withdrawn), channel (for sub-channel purposes like Marketing), granted-at and withdrawn-at timestamps, consent method (onboarding / settings / support-agent-assisted / migration), the specific consent-artifact version the user was shown, source surface (app / web), and legal basis.

Data Schema (Simplified)

Table	Key Columns	Purpose
consent_events	event_id, user_id, purpose_id, channel, previous_state, new_state, method, artifact_version, actor, created_at	Append-only, immutable event log — the source of truth for audit and history
consent_current_state	user_id, purpose_id, channel, current_state, last_changed_at, purpose_version	Materialised, fast-read view for runtime consent checks (checkout, personalisation, marketing send)
purpose_registry	purpose_id, name, version, description, legal_basis, default_state, effective_from	Versioned definition of each purpose, decoupled from application code so legal/copy updates don't require a release

Versioning

Every purpose has a version number. Cosmetic copy edits do not increment the version; changes that materially alter what a purpose covers do, and trigger re-consent for affected users per requirement CONS-008.

Purpose Identifiers

- PURPOSE_ESSENTIAL
- PURPOSE_PERSONALIZATION

- PURPOSE_MARKETING_EMAIL / PURPOSE_MARKETING_SMS / PURPOSE_MARKETING_WHATSAPP / PURPOSE_MARKETING_PUSH
- PURPOSE_PARTNER_SHARING

Consent History & Audit Logs

consent_events is the append-only historical record; nothing is ever updated or deleted in place. Audit logs are retained per a schedule to be confirmed with Legal (see Section 18) and stored in a write-once, tamper-evident store separate from operational databases.

Revocation Handling

A withdrawal creates a new consent_events row and publishes an event to downstream systems (marketing platform, recommendation pipeline, partner-export job) via an event bus. Each downstream system commits to the propagation SLA defined against SYS-001.

Migration Strategy

A one-time backfill job assigns existing users a “legacy/unknown” state in consent_current_state. These users are re-prompted for explicit consent at next app open ahead of Phase 3 enforcement, rather than being assumed compliant by default.

Cross-Platform Propagation

A shared consent service is used by Instamart, Swiggy Food, Genie, and Dineout so that a withdrawal for a shared purpose is honoured ecosystem-wide. Partner Sharing is scoped to Instamart specifically unless a user separately consents on another surface.

Retention Policies

Consent records are retained per the data-retention schedule agreed with Legal. Underlying personal data is purged on a valid deletion request, subject to statutory retention exceptions (e.g. financial and tax records), which are disclosed to the user at the point of the deletion request per requirement DATA-002.

13. Analytics Instrumentation

Event Name	Key Properties	Trigger Condition	Owner
consent_viewed	user_id, screen_name, purpose_ids_shown, entry_point	A consent-related screen is rendered	Product Manager, Privacy & Trust
consent_toggle_changed	user_id, purpose_id, previous_state, new_state, screen	User taps a category or channel toggle	Product Manager, Privacy & Trust
consent_submitted	user_id, purposes_granted[], purposes_denied[], consent_version, entry_point	User confirms/saves preferences (onboarding or settings)	Product Manager, Privacy & Trust
consent_withdrawn	user_id, purpose_id, withdrawal_method	A previously granted purpose is turned off post-onboarding	Product Manager, Privacy & Trust

Event Name	Key Properties	Trigger Condition	Owner
data_request_initiated	user_id, request_type (access/delete), entry_point	User submits a data access or deletion request	Trust & Safety Operations
data_request_completed	user_id, request_type, fulfilment_time_hours, status	Backend asynchronous fulfilment job completes	Trust & Safety Operations

Dashboard Recommendations

A weekly Privacy Health dashboard should track: Valid Consent Coverage trend, onboarding completion rate, data-rights request volume and SLA compliance, and guardrail metrics (recommendation CTR, order conversion, uninstall rate) — segmented by platform, city, and user cohort, consistent with the mock dashboard in the source strategy deck.

14. Experimentation Strategy

Can be A/B tested	Cannot be tested
Copy and tone of consent explanations Information hierarchy / ordering of purpose cards Visual treatment (icons, colour, layout) Toggle ordering within a screen Nudge banners encouraging users to review settings	Whether data-principal rights are offered at all Opt-in defaults for optional purposes — must be off/neutral for every user, not a test variant Withdrawal capability — must exist for 100% of users Any compliance-mandated disclosure text

The guiding rule: anything that changes how well a user understands or exercises a legal right must not vary by test cell. Only presentation-layer variables are eligible for experimentation.

15. Rollout Plan

Phase 1 — Privacy Center

Field	Detail
Scope	Read-only transparency page explaining current data practices; no functional toggles yet. Soft launch to 5% of users.
Dependencies	Legal and content sign-off on plain-language copy; translation for launch locales
Success criteria	Adequate page engagement; comprehension signal via in-app micro-survey; no negative impact on core ordering funnel
Risks	Users may expect functional controls and be confused by a view-only page
Go/No-Go	Comprehension survey meets an agreed threshold and funnel metrics show no regression before proceeding to Phase 2

Phase 2 — Granular Controls

Field	Detail
Scope	Full Privacy Hub with category toggles live; copy and layout under A/B test

Field	Detail
Dependencies	Consent backend service (Section 12) live; analytics events (Section 13) instrumented
Success criteria	Consent completion rate $\geq 90\%$; guardrail metrics within bounds
Risks	Consent fatigue; toggle confusion; support-ticket increase during rollout
Go/No-Go	Guardrail metrics stay within agreed bounds for two consecutive weeks before Phase 3

Phase 3 — Purpose-Based Consent (Enforced)

Field	Detail
Scope	Mandatory explicit consent for new users; existing users migrated via an in-app re-consent nudge
Dependencies	Legal sign-off; backfill migration job (SYS-003) complete; cross-platform propagation (SYS-002) live
Success criteria	Valid Consent Coverage $\geq 85\%$ within 60 days of this phase going live
Risks	Existing-user pushback; possible short-term spike in support tickets
Go/No-Go	Legal sign-off obtained, VCC trending toward target, and support capacity confirmed to absorb the migration volume

Phase 4 — AI Transparency & Parental Consent

Field	Detail
Scope	“Why am I seeing this” recommendation explainability; verifiable parental consent flow for family/child profiles (Section 9)
Dependencies	Recommendation team's explanation API; identity/age-verification capability
Success criteria	Reduced recommendation-related complaint rate; parental-consent completion rate for flagged accounts
Risks	Age-verification false positives/negatives; meaningful engineering lift
Go/No-Go	Legal and child-safety review sign-off obtained before enforcement begins

16. Risks and Trade-offs

Risk	Impact	Likelihood	Mitigation	Owner
Consent fatigue	Users disengage or accept without reading, undermining the value of explicit consent	Medium	Group into 4 categories (not per-datapoint toggles); progressive disclosure for channel-level detail	Design / PM
Lower conversion at onboarding	Revenue impact from added friction at signup	Medium	Target sub-15-second consent flow; “quick setup” path with visible, non-hidden defaults	Growth PM

Risk	Impact	Likelihood	Mitigation	Owner
Reduced personalisation data volume	Recommendation quality and related revenue may dip	Medium–High	Invest in non-PII, contextual recommendation fallback for opted-out users	Personalisation Team
Engineering complexity retrofitting cross-platform flows	Delivery delays; integration defects across Instamart/Food/Genie/Dineout	High	Phased rollout; dedicated platform squad; shared consent service as single source of truth	Engineering Lead
Cross-product dependencies	Inconsistent consent state across the Swiggy ecosystem if surfaces update independently	High	Central consent service, contract tests between surfaces, shared purpose taxonomy	Platform Engineering

17. Edge Cases

Edge Case	Handling
Users rejecting all optional consent	Core ordering must remain fully functional; only the Essential category is ever enforced
Guest checkout	Essential-only consent captured per session; no persistent optional-consent record; account creation offered for granular control (CONS-007)
Family accounts	Primary account holder manages consent by default; dependents are routed to the parental consent flow if identified as minors
Children	Verifiable parental consent required (Phase 4); restrictive defaults apply until verification is complete
Mid-order deletion requests	Deletion is scheduled to complete after the current order finishes; order data is retained only as statutorily required, with the rest of the profile scrubbed
Inactive users (e.g. 12+ months dormant)	Consent is treated as stale; user is re-prompted at next login before any personalised or marketing processing resumes
Consent expiry / purpose changes	A material purpose-version change triggers re-consent (CONS-008); no indefinite silent validity is assumed
Multiple devices	Consent state is account-level and server-side, synced across devices in near-real-time
International users ordering in India	DPDP applies based on processing of personal data of individuals located in India; exact jurisdictional scope for edge cases (e.g. NRIs ordering remotely) should be confirmed with Legal — see Section 18

18. Open Questions

Legal

- Does a “quick setup with recommended defaults” screen — where optional toggles are pre-selected but the user must still take an affirmative confirm action — meet DPDP's bar for clear, affirmative consent, or must every optional purpose default to off with no pre-selection at all?
- What are the exact statutory timelines for fulfilling data-rights requests, and the specific penalty thresholds, under current DPDP rules and any subsequently notified rules?

- What is the required retention period for consent and audit logs?
- What is Instamart's jurisdictional exposure for users located outside India at the time of ordering (e.g. NRIs)?

Engineering

- Can the current data platform support real-time consent-propagation webhooks across Instamart, Swiggy Food, Genie, and Dineout, or is a batch cadence (e.g. hourly) acceptable for an initial launch?
- What is the realistic peak QPS the consent service needs to support at festival-level traffic spikes?

Analytics

- How should Valid Consent Coverage treat users who have not opened the app since launch — excluded from the denominator, or counted as non-compliant?

Operations

- Who owns manual fulfilment of data-rights requests during Phases 1–2, before full automation is live?

Customer Support

- What is the support script and escalation path for users confused by the new consent prompts, and for disputes arising from the parental-consent flow?

19. Appendix

Consent Taxonomy

Purpose ID	Definition
PURPOSE_ESSENTIAL	Order fulfilment, delivery, and payment processing
PURPOSE_PERSONALIZATION	Recommendations and personalised search ranking
PURPOSE_MARKETING_EMAIL / SMS / WHATSAPP / PUSH	Promotional and re-engagement communication, per channel
PURPOSE_PARTNER_SHARING	Aggregated, anonymised insights shared with brand/FMCG partners

Glossary

Term	Meaning
Data Principal	The individual to whom the personal data relates (the user)
Data Fiduciary	The entity that determines the purpose and means of processing personal data (Instamart/Swiggy)
Consent Manager	An accountable, DPDP-recognised entity through which a user can manage consent across multiple platforms
Purpose Limitation	The principle that personal data should only be processed for the specific purpose it was collected for

Term	Meaning
Data Protection Board	The regulatory body established under the DPDP Act to handle grievances and enforcement

DPDP References

This PRD references the Digital Personal Data Protection Act, 2023 (Government of India) at a conceptual level — consent and notice requirements, children's data protections, and data principal rights. Section numbers are not cited here with legal certainty; Legal should validate exact statutory citations, along with any rules subsequently notified under the Act, before they are used in user-facing copy or external communication.

Assumptions

- This PRD is derived from a product-thinking exercise based on publicly observable app behaviour; no internal Swiggy documentation, data, or systems knowledge was used.
- Personas (Rahul, Priya) are illustrative and not sourced from user research; they should be validated before detailed design work begins.
- Metric targets (e.g. 85% Valid Consent Coverage, sub-15-second onboarding) are proposed starting points for alignment, not committed targets — Analytics and Leadership should confirm baselines before these are finalised.
- The MVP prototype referenced in this document (see Reference Artifacts on the cover page) implements the happy-path onboarding and dashboard flows only; edge cases and Phase 4 flows are specified here but not yet built.

Future Roadmap

- Extend the shared consent service into a full Consent-as-a-Service layer for all Swiggy ecosystem apps.
- Build a self-serve DPDP grievance-redressal portal, reducing reliance on generic customer support.
- Introduce an automated Data Protection Impact Assessment (DPIA) pipeline for new features that touch personal data.
- Extend AI-transparency explainability beyond recommendations to search ranking and pricing/offers personalisation.